MICROSOFT 365 / IDENTITY INCIDENT

M365 Identity Incident Triage Checklist

A printable, evidence-first worksheet for the first response to a suspicious sign-in or suspected account compromise.

Use this as a triage aid, not a verdict. A new location, unfamiliar IP, or failed sign-in is not proof of compromise by itself. Correlate identity, device, mailbox, application, and audit evidence; follow your organisation's incident-response process.

Incident / alert ID: _____	Analyst: _____
Account / UPN: _____	Tenant: _____
First suspicious event (UTC): _____	Last observed (UTC): _____

01 Preserve evidence and establish scope

START HERE

[ ] Record the alert source, detection name, affected user, timestamps (UTC), relevant IPs, device/app IDs, and event/correlation IDs. Preserve screenshots or export logs before they age out.

[ ] Set a working time window: begin before the first suspicious event and continue through the response actions. Record the reason for expanding or narrowing it.

[ ] Separate confirmed facts, reported information, and hypotheses. Do not describe an anomaly as malicious until corroborated.

[ ] Identify business impact and the incident owner. Coordinate account disabling, device isolation, or broad policy changes before applying them.

02 Review Microsoft Entra sign-ins

IDENTITY

Path: Microsoft Entra admin center Entra ID Monitoring & health Sign-in logs. Review both interactive and non-interactive activity for the affected account and the incident window. Open individual events and inspect Authentication Details and Conditional Access results.

[ ] For each candidate event capture: success/failure, timestamp, IP and location, application and resource, client, device ID / managed / compliant state, authentication method and result, Conditional Access status, Request ID, and Correlation ID.

[ ] Look for a coherent sequence: unexpected successful sign-in, suspicious authentication or token activity, followed by mailbox/app changes or data access. Compare with the user's normal pattern and known VPN / proxy / travel.

[ ] Do not treat geolocation, impossible-travel heuristics, or one unfamiliar IP as conclusive. Check whether the sign-in was interactive or non-interactive and whether policy/MFA was satisfied by a token claim.

INVESTIGATE THE PATHS THAT CAN KEEP ACCESS

A compromised identity can affect email, files, apps, and devices. Correlate the same time window across sources; absence of a log is not proof that an action did not occur.

03 Check directory changes and persistence

AUDIT

- [ ] In Entra audit logs, check for password resets, authentication-method/security-info changes, device registrations, role/group membership changes, Conditional Access policy edits, app registrations, service-principal credential changes, and consent grants.
- [ ] For any change, capture actor, target, time, source IP (when available), operation, modified properties, and whether the change was expected and authorized.
- [ ] For app consent, identify the app, publisher, requested Graph/API permissions, who granted them, and whether the app or grant is still required. Do not delete a legitimate enterprise app based only on an unfamiliar display name.

04 Inspect mailbox and collaboration activity

MAILBOX / DATA

- [ ] In Exchange Online, review mailbox forwarding and Inbox rules (including hidden rules). Look for external recipients, unexpected deletion/move rules, and changes made during the suspicious window.
- [ ] In Microsoft Purview audit search, investigate mailbox sign-ins, rule creation/modification/removal, forwarding changes, and relevant message access. Use Message Trace and Sent Items to scope suspicious outbound mail.
- [ ] In SharePoint / OneDrive / Teams, look for unusual file access, downloads, sharing links, app access, or activity associated with the affected identity. Check Defender XDR incidents for correlated users, devices, mailboxes, and cloud apps.

Read-only Exchange Online checks — connect to Exchange Online PowerShell with an authorized account. Replace the sample UPN. These commands inspect state; they do not change it. Validate whether a rule is legitimate before considering remediation.

```
Get-InboxRule -Mailbox user@contoso.com -IncludeHidden |
Format-List Name,Enabled,RedirectTo,ForwardTo,ForwardAsAttachmentTo

Get-Mailbox user@contoso.com |
Format-List ForwardingSmtpAddress,ForwardingAddress,DeliverToMailboxAndForward
```

Evidence threshold: A sign-in anomaly alone may have a benign explanation. Confidence rises when multiple independent signals align—for example, a successful unusual sign-in followed by an unrecognized auth-method change, app consent, mailbox rule, or data-access event.

CONTAIN, VERIFY, HAND OVER

Choose containment based on evidence, active risk, business impact, and your authority. Preserve evidence and document the reason for every response action.

05 Contain confirmed or ongoing compromise

CONTROLLED ACTION

[ ] If active misuse is confirmed or strongly evidenced, coordinate with the incident owner. Consider temporarily blocking sign-in when needed to stop ongoing harm; this interrupts the user's access and can affect business operations.

[ ] From a trusted admin session/device, reset credentials and revoke the user's Entra sessions. Microsoft notes that the time to lose access depends on token/session behaviour; do not assume every application signs out instantly.

[ ] If authentication methods may be compromised, remove or require re-registration of only the affected methods after confirming the user through a trusted process.

[ ] Remove unauthorized app grants, credentials, roles, mailbox forwarding, or rules only after validating the evidence and documenting the change. Preserve relevant audit records first.

[ ] If a device is implicated, use your endpoint response process (for example, Defender device isolation) only when the evidence and incident authority justify it.

06 Verify remediation and monitor

CLOSE THE LOOP

[ ] Confirm that new sign-ins follow the expected authentication and Conditional Access path; review post-containment sign-ins and risky-user status if licensed.

[ ] Re-check the specific persistence points found: auth methods, sessions, app permissions/credentials, roles, mailbox forwarding/rules, outbound mail, and relevant file/app activity.

[ ] Search for related identities, devices, apps, IPs, or message recipients—but do not broaden the incident scope solely because a value is shared or unfamiliar.

[ ] Record actions, timestamps, approvals, user impact, remaining uncertainty, monitoring owner, and the criteria for closing or escalating.

07 Record the current assessment

HANDOVER

[ ] No evidence of compromise found so far	[ ] Anomalous; insufficient evidence to classify as malicious
[ ] Likely compromised; containment started	[ ] Confirmed compromise; response / escalation active
Evidence still needed: _____	
Owner / next check / due time (UTC): _____	

MICROSOFT PRIMARY REFERENCES

Entra sign-in logs and event details https://learn.microsoft.com/en-us/entra/identity/monitoring-health/concept-sign-ins

Access Microsoft Entra activity logs https://learn.microsoft.com/en-us/entra/identity/monitoring-health/howto-access-activity-logs

Revoke user access in an emergency https://learn.microsoft.com/en-us/entra/identity/users/users-revoke-access

Plan an incident response workflow in Defender https://learn.microsoft.com/en-us/defender-xdr/plan-incident-response

Respond to a compromised Microsoft 365 email account
https://learn.microsoft.com/en-us/defender-office-365/responding-to-a-compromised-email-account

Identify who modified Exchange inbox rules https://learn.microsoft.com/en-us/purview/audit-log-identify-mailbox-rules

Security Brief is an independent educational publication. This checklist is a starting point, not an incident determination, legal advice, or a substitute for your tenant's runbooks, licensing requirements, or Microsoft documentation. Verify current portal labels and feature availability before acting.